

# RBAC SYSTEM DESIGN

## Contents

**Introduction ..... 2**

**RBAC System OS Controls..... 3**

**RBAC System Network Controls ..... 4**

**RBAC System Account Controls ..... 5**

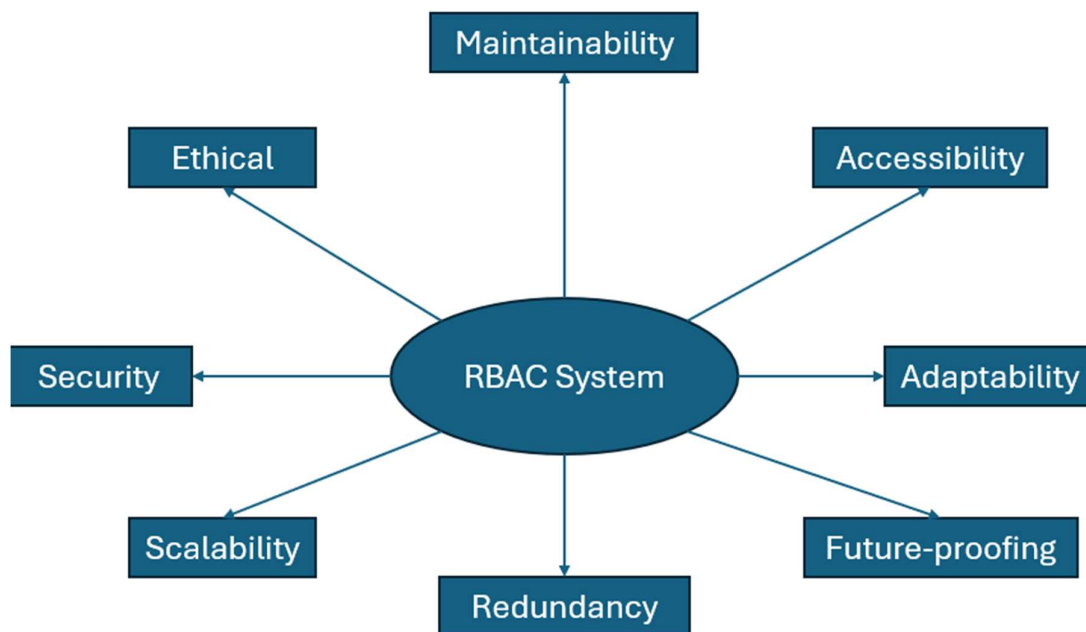
**RBAC System Administrator Workflow ..... 6**

**RBAC System Trade-Offs..... 7**

## Introduction

This RBAC system is designed to help companies and users protect against insider threats. It is also designed to reduce the blast radius of malware and account compromise. This RBAC system was created as insiders are currently one of the most dangerous threat actors in cybersecurity. It was also created to provide users and companies with more control over their systems. This RBAC system has features across operating systems, networks and accounts. Most of these controls work within pre-existing systems. These controls will have to be adapted to specific company or personal systems based on resources and budget.

This RBAC system cannot promise to fully prevent insider threats or provide complete control over systems. Instead, this system can promise to increase detection and prevention rates of insider threats. The system can also provide more control over permissions and access across all 3 layers. This RBAC system may be time-consuming and difficult to implement in the short-term however it will be cost-effective and more secure in the long-term.



The spider diagram above shows the design principles used in this RBAC system. This does not show all the principles that the RBAC system was designed with. Other principles can include reliability, consistency and efficiency.

## **RBAC System OS Controls**

- These RBAC system OS controls may be the easiest to implement on Windows and Linux.
- This RBAC system OS controls provide two starting roles.
- The first role is the admin user role.
- The admin has full access within OS limitations.
- The admin can create custom roles, set password policies, delete, log out, or send a warning message to user.
- They can also set recovery policies for example, administrators or certain custom roles are allowed to reset passwords for other users.
- The second role is standard user role
- By default, the standard user cannot access core security settings, system files, or other user's files.
- The standard user's permissions can also be configured by the admin user.
- The standard user should still be able to access certain settings like accessibility or personalization features.
- For custom roles, admin must define a name, assign users and control permissions and software access, password policy and recovery policy.
- For password policy, admin users can set the minimum number of characters, rate-limiting, progressive lockout and password expiration date.
- For recovery policies, admin users can set what roles can use recovery keys, have admins reset their password or even use security questions to recover accounts.
- If standard or a custom role tries to access software or resources that require admin permissions, they are prompted for an admin password.
- This attempt is logged and an automated alert is sent to the admin.
- This same process also occurs when privilege escalation is attempted.
- Admins can delete the user's account completely, log them out or send a warning with an automated message or a custom message.
- For example, the default automated message may be "Warning: This action requires admin permission. Please contact your administrator for any issues"
- It is important that admins acknowledge user mistakes as it may be confusing to understand certain permissions.
- Admins can also use a priority system for the logging alerts.
- This priority system would allow the administrator to set levels like critical, medium or low depending on what resource was accessed
- This is useful because the admins do not get overloaded by the constant hundreds or thousands of logs that may occur in larger systems.
- These logs should also be verified using a verification hash to ensure that they haven't been tampered with.
- This OS layer will have to be adapted as no operating system currently supports all the features.

## **RBAC System Network Controls**

- These RBAC system network controls mainly work with current existing systems like WPA3-personal and WPA3-Enterprise.
- It may also be compatible with WPA2 security protocols, but it may be less effective due to older security protocols.
- This RBAC system has different controls for WPA3-personal and WPA3-enterprise.
- For WPA3-personal, this RBAC system focuses on controlling access to network resources, not user permissions.
- Admin users can control the user's permissions to certain network resources by using the operating system controls.
- This is because the admin user can restrict access to certain server or printer resources by defining permissions on standard and custom roles.
- For example, employees working as cashiers would not have access to customer data on company servers.
- Admin can set which roles have permissions based on user accounts on the operating system or the domain.
- This WPA3-personal approach is limited because admins cannot directly control permissions via the network.
- For WPA3-enterprise, this RBAC system can directly support custom, standard and admin roles.
- The admin role would have full access to server resources, user permissions and network services.
- They can also control user credentials, permissions, and logging.
- All interactions are logged to a centralized system which in this case would be the RADIUS server.
- Admin can search for logs or use a defined priority system to handle the hundreds or thousands of logs
- The logs are also verified by a verification hash to ensure that the log database hasn't been tampered with at all.
- Admins can also configure the system to use the user's OS credentials as their network credentials
- This is important so the admins do not have to manually set credentials for hundreds or thousands of users.
- Admins can still configure credentials personally for certain custom roles or for their own network credentials.
- This WPA3-enterprise approach is the most effective approach this RBAC system can support.
- This is because it is linked with the operating system layer and allows for more control over the network.

## **RBAC System Account Controls**

- This RBAC system's account controls are mainly for companies with websites.
- This will have to be adapted for personal systems if individuals want to use it.
- For example, individuals may have to separate identities, use different providers and use different credentials for each account.
- For the RBAC system account controls it uses the same approach as the OS and network layers.
- The admin can define custom roles, permissions and logging systems.
- Admins can also control MFA policy and password policy for each role.
- For MFA policy, admins may set hardware keys for themselves and important custom roles.
- They may set authentication app or email-based for standard users or less sensitive custom roles.
- For password policy, admins may set stricter rate-limiting like 3 failed attempts before a 30-minute lockout for their own accounts or important custom roles
- They may set a password policy of 5-6 failed attempts before a 10–20-minute lockout for standard users.
- For recovery policies, admins may be able to use recovery keys, recovery kits or backup codes to recover their accounts
- Standard users may use admin-based recovery or some in rare cases recovery key.
- Admins would be able to use OS credentials to set account credentials for consistency and efficiency.
- For the logging systems, it would be centralized, use a verification hash and sent to admin-defined server or database.
- There are 3 main log formats that the admins may see
- The first log format is for account sessions
- This would tell the admin who the user is, timestamp for login, IP address (Optional), session duration, logout timestamp.
- The second log format is for failed attempts
- This would tell the admin who the user is, timestamp for the beginning of the attempt, how many failed attempts, if lockout was activated, timestamp of lockout, lockout duration, IP address.
- The third log format is for access attempts
- This would tell the admin who the user is, what was accessed, priority level, timestamp of access, what action did the user take, IP address (Optional)
- These log formats can all be chosen or configured by the administrator when setting up the logging system.
- It is important that admins consider the privacy of the users in the company as these log formats can be intrusive.

## **RBAC System Administrator Workflow**

- The administrator sets up an admin user account on their operating system.
- After setting up the account, the administrator creates a domain to connect all company computers together.
- Once the domain is set up, the administrator creates standard and custom user roles.
- The custom user roles include Executive, HR and Accounting while the rest of the employees have standard user accounts.
- The admin then provides permissions to each custom role. HR has access to customer data. Executive has access to employee data. Accounting has access to the company's financial data.
- For password policy, the admin sets 8 characters minimum with 5 failed attempts before 10 minutes lockout.
- For recovery policy, admins and executives can reset their password and access recovery keys for device encryption. All other roles must use admin-based recovery.
- For logging, the admin sets up a priority system that uses critical for access attempts on customer or employee data.
- They also create the verification hash to ensure that the logs aren't tampered with.
- The admin also sets up an automated message for privilege escalation attempts for example "Warning: This action requires admin permissions to perform. Please contact your administrator for more information"
- After setting up the OS RBAC system, the administrator moves to setting up the network.
- The administrator sets the Wi-Fi security protocol to WPA3-enterprise.
- The administrator configures all users network credentials to use their operating system credentials.
- They also set the same password policy per role, same recovery policy per role and same logging systems for the network for consistency.
- The administrator also configures the custom roles with permissions to certain network resources like servers or printers.
- After setting up the network RBAC system, the administrator moves to setting up the accounts
- The administrator configures all the accounts to use the same credentials as the OS and network versions.
- The administrator uses a recovery policy of recovery backup codes for themselves and some custom roles.
- For MFA policy, admins and executives use hardware keys while all other roles use authentication app for MFA.
- The administrator uses all 3 log formats for logging certain custom role sessions and access to customer and employee data.

## **RBAC System Trade-Offs**

- This RBAC system has 6 main trade-offs.
- There may be more trade-offs during implementation.
- The first trade-off is Compatibility.
- This trade-off exists because the RBAC system is currently not supported fully on any operating systems and it is limited mainly to PC operating systems only.
- This trade-off can be managed through creating custom operating systems, adapting controls where needed and focusing on PC operating systems for sensitive activities.
- The second trade-off is Unified Credentials.
- This trade-off exists because the RBAC system allows for admins to use the same credentials across all 3 layers.
- This means that if an attacker were to gain the credentials, they could compromise a user across all 3 layers.
- This trade-off can be managed through secure password storage, separate credentials for admin or sensitive custom roles and security awareness training.
- The third trade-off is Privacy.
- This trade-off exists because the RBAC system allows for admins to collect a large amount of data due to the logging systems across each layer.
- This trade-off can be managed through privacy regulations, using VPN or proxies and separating personal activities from work.
- The fourth trade-off is Set-up.
- This trade-off exists because it can be time-consuming and heavy to set up multiple roles and permissions on a system across 3 layers.
- This trade-off can be managed through adaptation of controls, multiple admin users and using the automated controls.
- The fifth trade-off is Performance.
- This trade-off exists because all these security features can be computationally intensive and can slow down devices or the network.
- This trade-off can be managed through load balancers, resource management, threat modelling.
- Threat modelling can help improve performance as companies or users only implement the security features they require.
- The sixth and final trade-off is Security.
- This trade-off exists because in some operating systems or using WPA2 it can limit the effectiveness of the RBAC system.
- This trade-off can be managed by updating tools where possible and adapting the RBAC system based on resources.